PCI DSS 4.0 – March 2022

Introduction

- PCI DSS provides a baseline of technical and operational requirements designed to protect account data.
- Specifically designed to focus on environments with payment card account data.
- Used to protect against threats and secure other elements in the payment ecosystem.

PCI DSS Versions

- PCI DSS v3.2.1 was valid till 31 March 2024, after which it is retired. All PCI DSS validations after this date must be to PCI DSS 4.0 or later.

Table 6. PCI DSS Versions

Version	Published	Retired
PCI DSS v4.0 (this document)	March 2022	To be determined
PCI DSS v3.2.1	May 2018	31 March 2024

Credit Card Data breach

Heartland Payment Systems

Date: March 2008
Impact: 134 million credit cards exposed through SQL injection to install spyware on Heartland's data systems.
Cost of Breach : $145 million

Target Stores

Date: December 2013
Impact: Credit/debit card information and/or contact information of up to 110 million people compromised
Cost of Breach : $162 million

Sony's PlayStation Network

Date: April 20, 2011
Impact: 77 million PlayStation Network accounts hacked; estimated losses of $171 million while the site was down for a month.

PCI-DSS: Security - Penalties

The Payment Card Industry has established fines of up to $500,000 per incident for security breaches when merchants are not PCI compliant

A hypothetical merchant compromises 10,000 accounts

- Notify clients
- Fines and penalties
- Increased audit needs
- Fraud liability
- Reputation Loss

- $30 x 10,000 = $300,000
- $50,000+
- $25,000 x 3 years = $75,000 (minimum)
- 500 accounts x $1,000 = $500,000
- PRICELESS!

Introduction

- PCI is not government legislation. It is not a federal law. PCI is an industry regulation.
- PCI DSS was the first unified security standard supported by all five of the major credit card brands.
- PCI DSS version 1 is dated 15 December 2004. The regulations took effect on June 30th 2005.

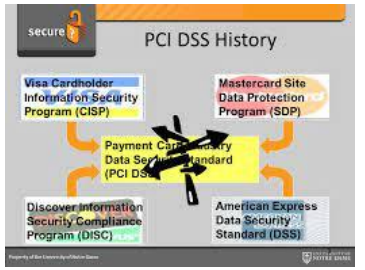
Applicability

- Entities with CDE where account data (cardholder data and/or sensitive authentication data) is stored, processed, or transmitted
- Entities with environments that can impact the security of the CDE
- Entities that are responsible for the protection of account data.

Introduction to PCIDSS

- The **Payment Card Industry Data Security Standard** (**PCI DSS**) is an information security standard is a widely accepted set of policies and procedures intended to optimize the security of credit, debit and cash card transactions and protect cardholders against misuse of their personal information.
- PCI DSS was developed to **enhance cardholder data security** and facilitate broad adoption of **consistent data security** measures globally
- Provides a baseline technical and operational requirements designed to protect account data

Introduction to PCI-DSS



- Visa card holder information security program (CISP) was announced in 1999
- Master cards site data Protection Program (SDP), Discover information security compliance program (DISC), American Express data security standard all followed their own unique security program.
- The lack of a unified standard caused confusion among merchants, many of them struggled to achieve compliance.
- Solution: Visa MasterCard Discover JCB and Amex decided to create a uniform set of regulations and data security standards
- Merchants are those entities what trying to comply with PCI DSS or anybody who is accepting payment online or at POS terminal



The PCI Council

- **Originally formed :** American Express, Discover, JCB, MasterCard and Visa Inc. (Payment Brands) on 7 September 2006.
- **Goal:** Managing the ongoing evolution of the Payment Card Industry Data Security Standard.
- The PCI Council is independent of Payment brands.



PCI Council

- Responsible for issuing new standards like PCI-DSS, PA DSS etc.
- Manages qualification and accreditation of QSA (qualified security assessor)/ASV (approved scanning vendor).
- Creates awareness and adoption of PCI standards by organising the PCI community annual conferences, special Interest Groups etc.
- Promotes participation and feedback to enhance payment security

Payment Brands

- Tracking and enforcement of PCI compliance
- Issue penalties, fees, deadlines
- Definition of merchants and service providers
- Responsible for forensics and account compromise investigation

PA DSS and PCI PTS

- PA DSS: Requirements for software vendors who develop payment applications that store, process or transmit cardholder data and/or sensitive authentication data.
- PCI PTS (Pin Transmission Security Standard): Requirements for devices used in the protection of cardholders PINs (Hardware Security Module-HSM, Shared Cash Dispensing - SCD)and other payment processing related activities.

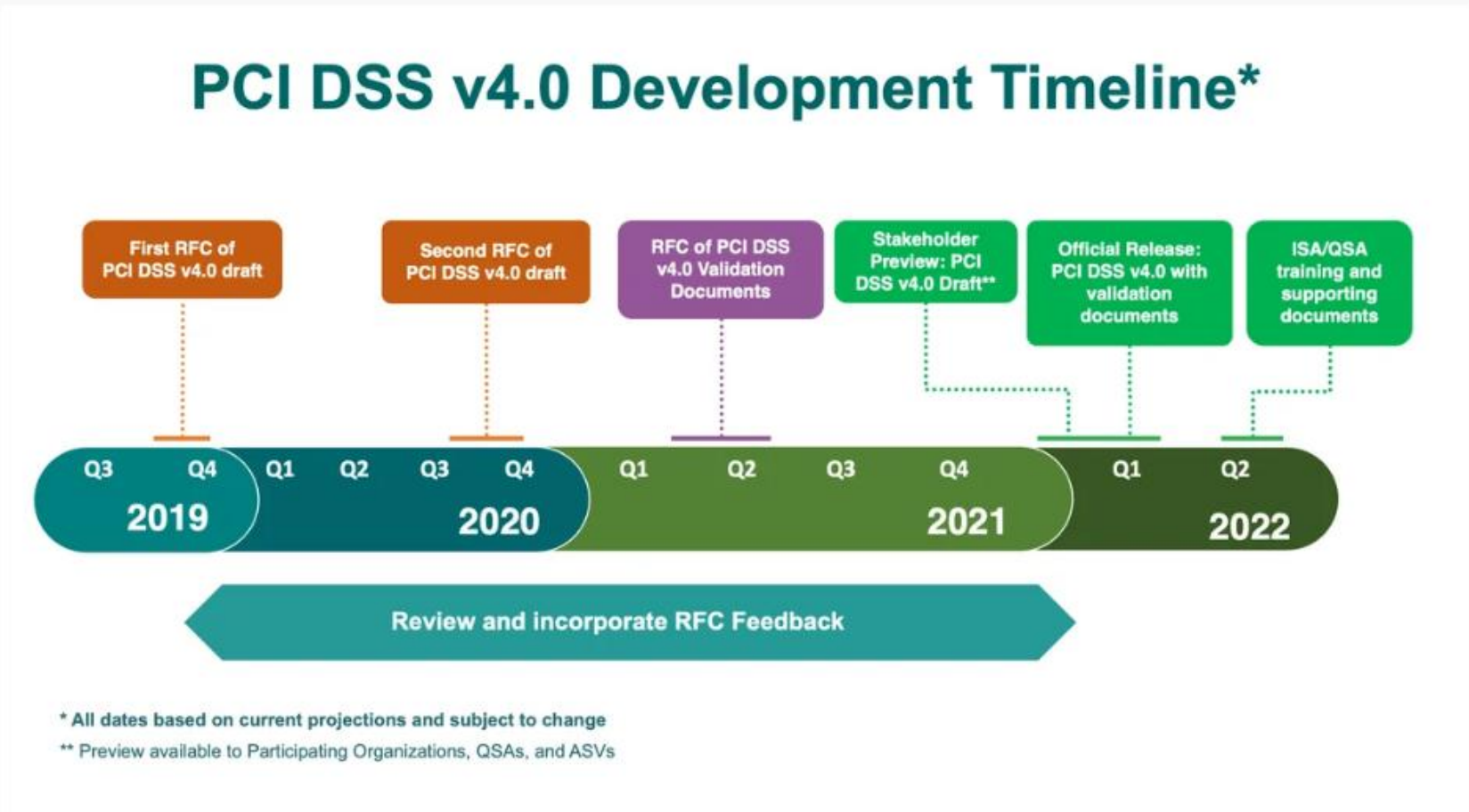
PAYMENT CARD INDUSTRY SECURITY STANDARDS

Protection of Cardholder Payment Data



Ecosystem of payment devices, applications, infrastructure and users

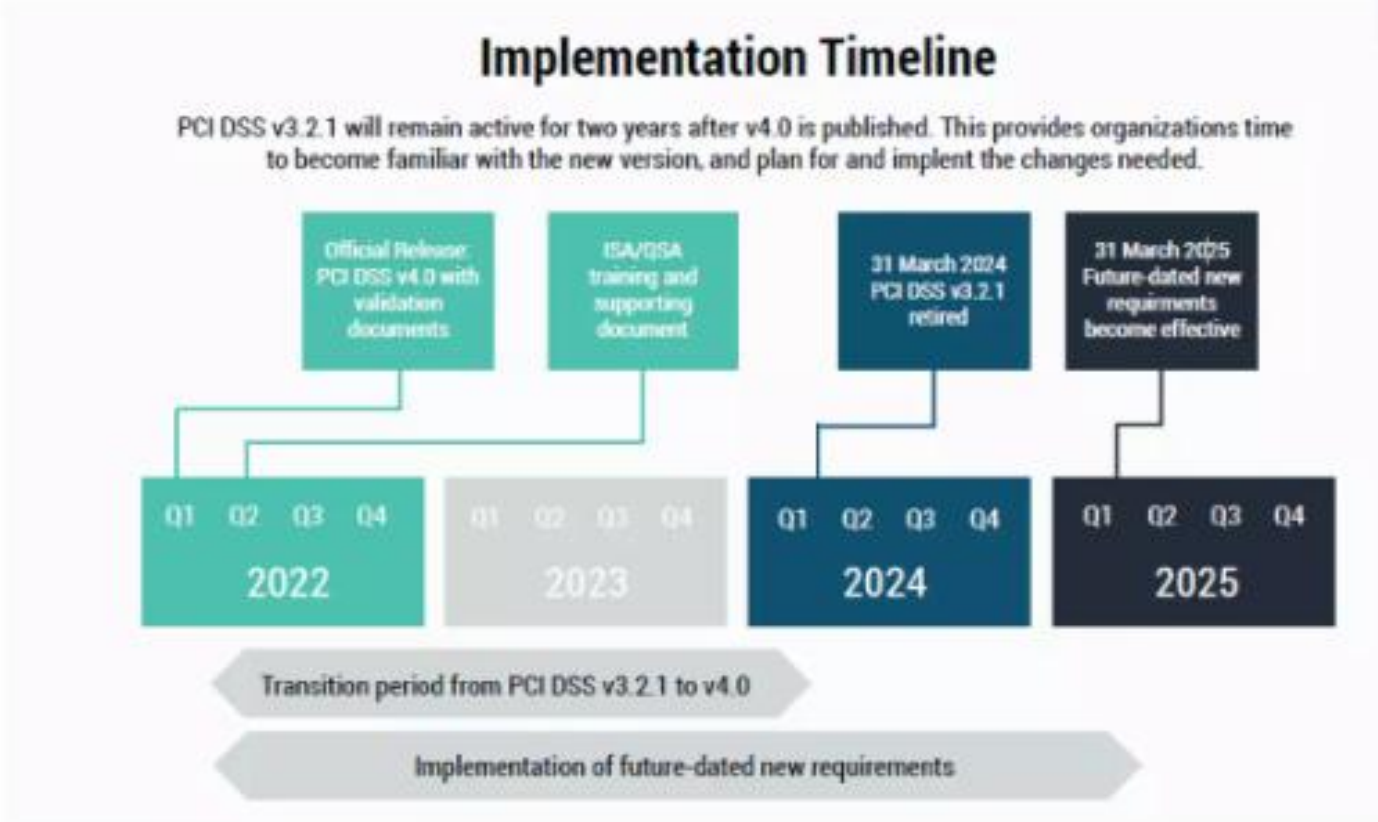
PCI DSS review cycle



Sourcs-https://blog.pcisecuritystandards.org/updated-pci-dss-v4.0-timeline

Transition timeline for PCI DSS 4.0

- **PCI DSS v3.2.1** is valid for assessment until **March 31, 2024**, upon which it will be retired.
- Until **March 31, 2024**, the organizations can use either the **v3.2.1** or **v4.0** standards for the assessments.
- From **April 1, 2024**, only **v4.0** will be the active PCI DSS standard that can be used for the assessments.
- All the future-dated new requirements will have additional 12 months (i.e., **until March 31, 2025**) before they become effective.



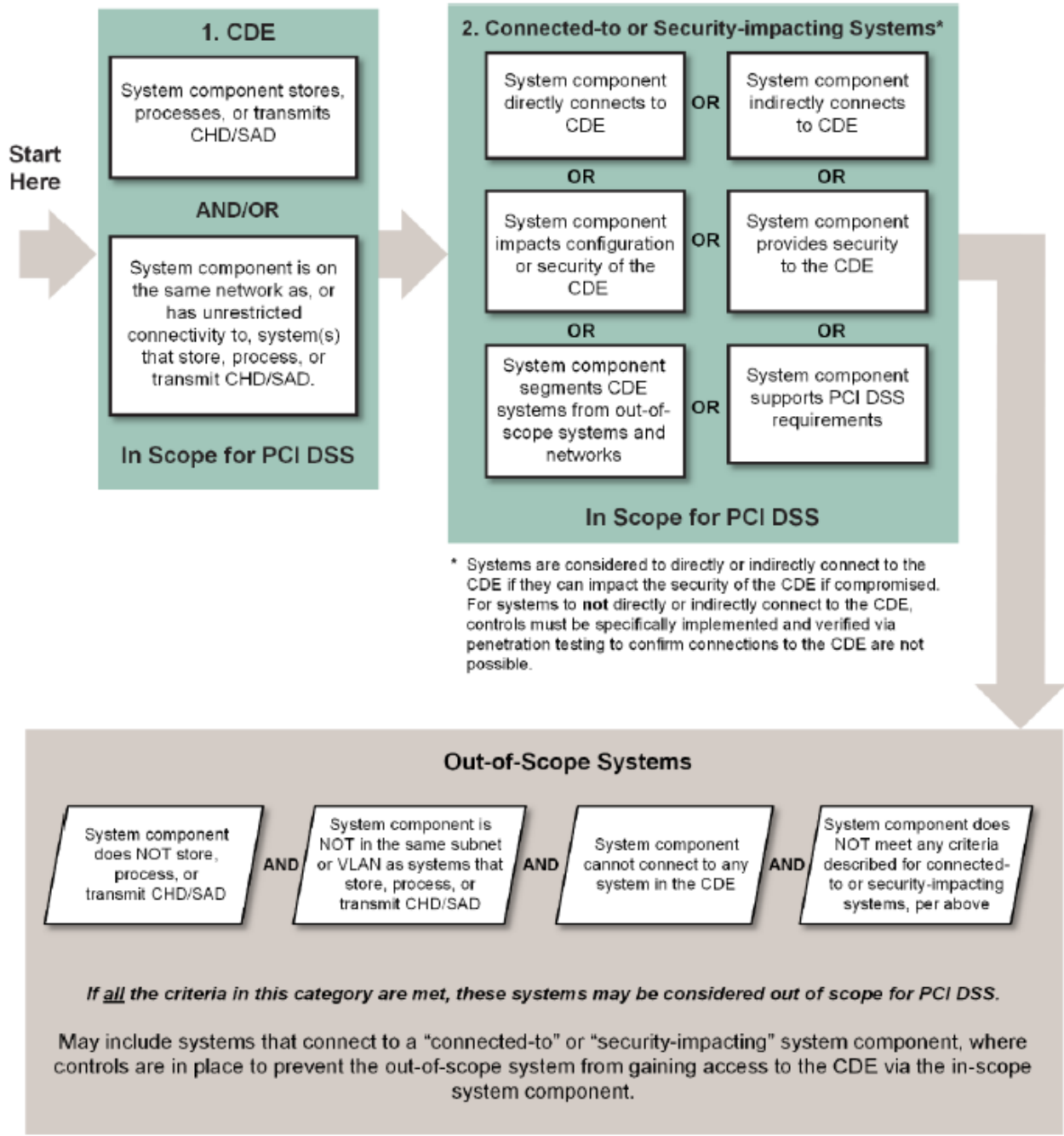
Source – PCI SSC

© ControlCase. All Rights Reserved.



https://blog.basistheory.com/credit-card-anatomy

Figure 1. Understanding PCI DSS Scoping



PCI DSS requirements apply to:

The cardholder data environment (CDE), which is comprised of:

- System components, people, and processes that store, process, and transmit cardholder data and/or sensitive authentication data, and,
- System components that may not store, process, or transmit CHD/SAD but have unrestricted connectivity to system components that store, process, or transmit CHD/SAD.

AND

- System components, people, and processes that could impact the security of the CDE
  - System components include network devices, servers, computing devices, virtual components, cloud components, and software.

Cardholder data

- Primary Account Number (PAN)
- Card Holder Name
- Expiration Date
- Service Code (SC)

Sensitive authentication data

- Full Track Data (Also Called Track Data Magnetic Stripe Data Or Equivalent On A Chip)
- Card verification code
- PINS/PIN blocks

Storage requirements

		Data Elements	Storage Restrictions	Required to Render Stored Data Unreadable
Account Data	Cardholder Data	Primary Account Number (PAN)	Storage is kept to a minimum as defined in Requirement 3.2	Yes, as defined in Requirement 3.5
		Cardholder Name	Storage is kept to a minimum as defined in Requirement 3.2[2]	No
		Service Code		
		Expiration Date		
	Sensitive Authentication Data	Full Track Data	Cannot be stored after authorization as defined in Requirement 3.3.1[3]	Yes, data stored until authorization is complete must be protected with strong cryptography as defined in Requirement 3.3.2
		Card verification code		
		PIN/PIN Block		

PCI DSS: Who all entities are at play?

Payment Brands



Banks



Merchants



Service Providers



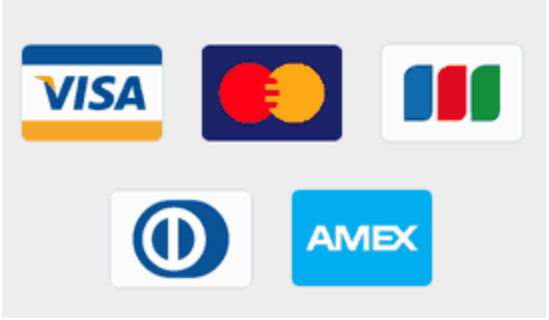
Entities in Payment Ecosystem



Cardholder



Merchant



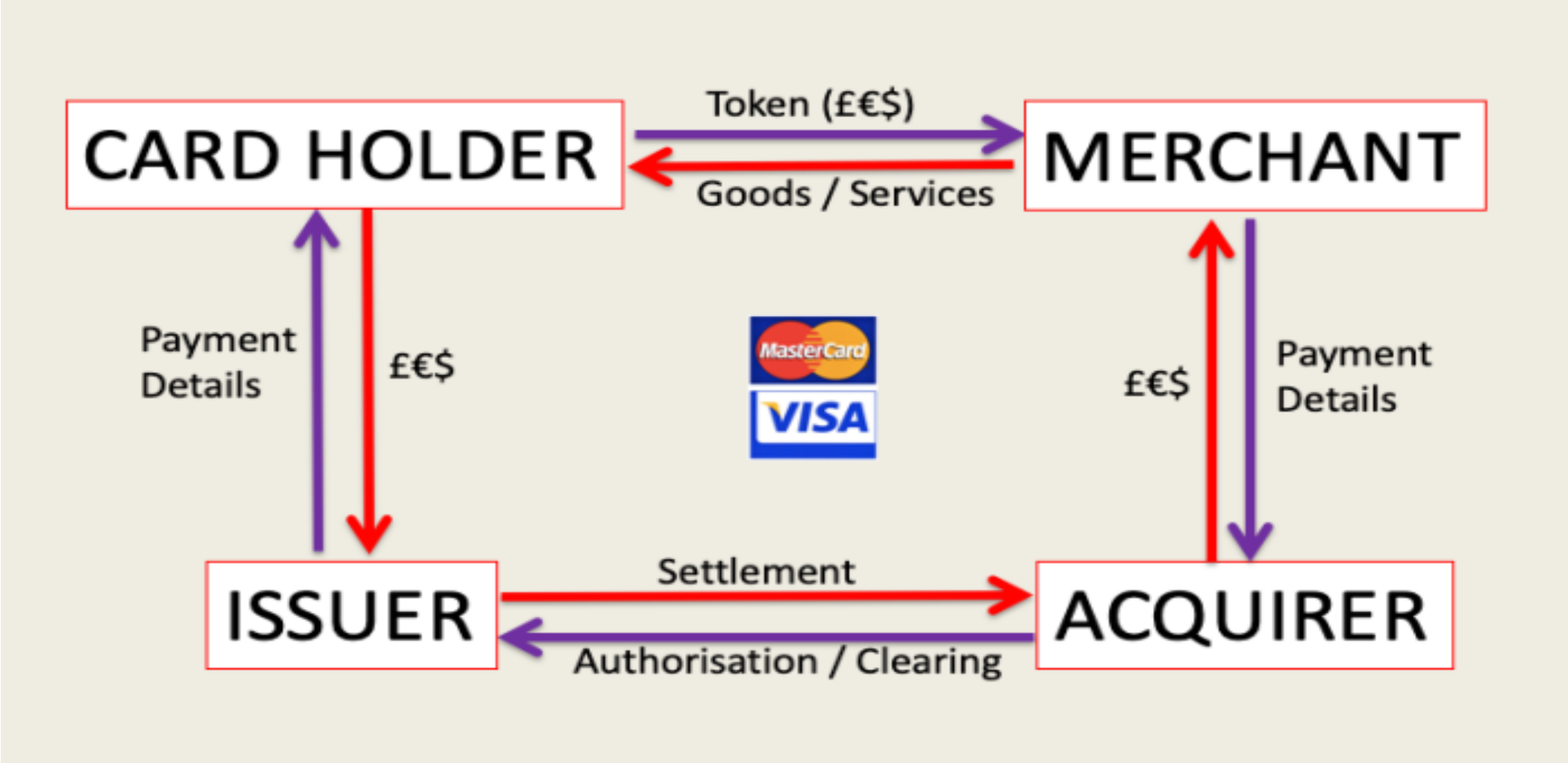


Issuer



Acquirer

Entities in Payment Ecosystem



PCI DSS Entities Acquiring Bank

- This is the bank with which a business or a Merchant hold their funds.
- Acquiring Bank will outfit merchants with card readers and equipment to accept card payments
- Acquiring Bank will deposit funds into the merchant’s account once a credit sale goes through.
- Example HSBC, CHASE, Wells Fargo, SBI

PCI DSS Entities Payment Brands

- Payment Brands transport data between the issuing bank and the merchant.
- Payment Brands are responsible for setting interchange and assessments.
- Most common Payment Brands are Vis, MasterCard, American Express, JCB and Discover.

Payment Brands



PCI DSS Entities Issuers

- Issuing Bank: this is the cardholder's bank, which gave him or her the credit cards they're using at the Merchant's store.
- Issuing Bank will determine whether the cardholder has the appropriate funds to complete a transaction, and then release the funds so that the transaction can settle.
- Examples of issuing banks are HSBC, Citi etc.

PCI DSS Entities: Merchants

- A Merchant is any entity that accepts payment cards bearing the logos of any of the five members of PCI SSC (American Express, Discover, JCB, MasterCard and Visa) as payment for goods and/or services.

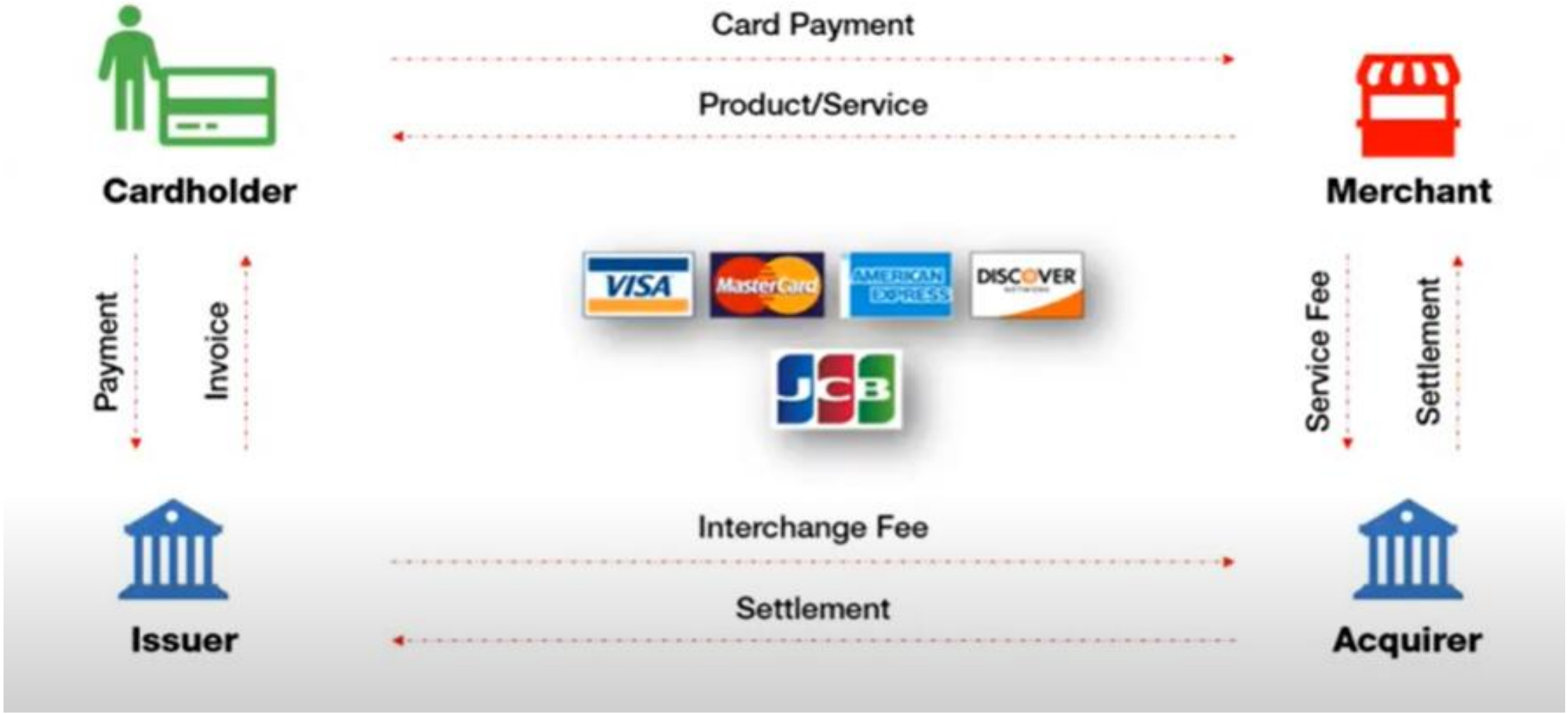
Merchant Levels

Merchant Level (Visa/Master Card)	Criteria
Level 1	Minimum of 6 million transactions per year
Level 2	1.5 to 6 million transactions per year
Level 3	20K to 1.5 million transactions per year
Level 4	Less than 20K transactions per year

Merchant Compliance Requirements

Level	QSA Onsite review	SAQ	Network Security Scan
Level 1	Required (Annually)	Not Required	Required (Quarterly)
Level 2	Not Required	Required (Annually)	Required (Quarterly)
Level 3	Not Required	Required (Annually)	Required (Quarterly)
Level 4	Not Required	Recommended (Annually)	Recommended (Annually)

Card Payment Process

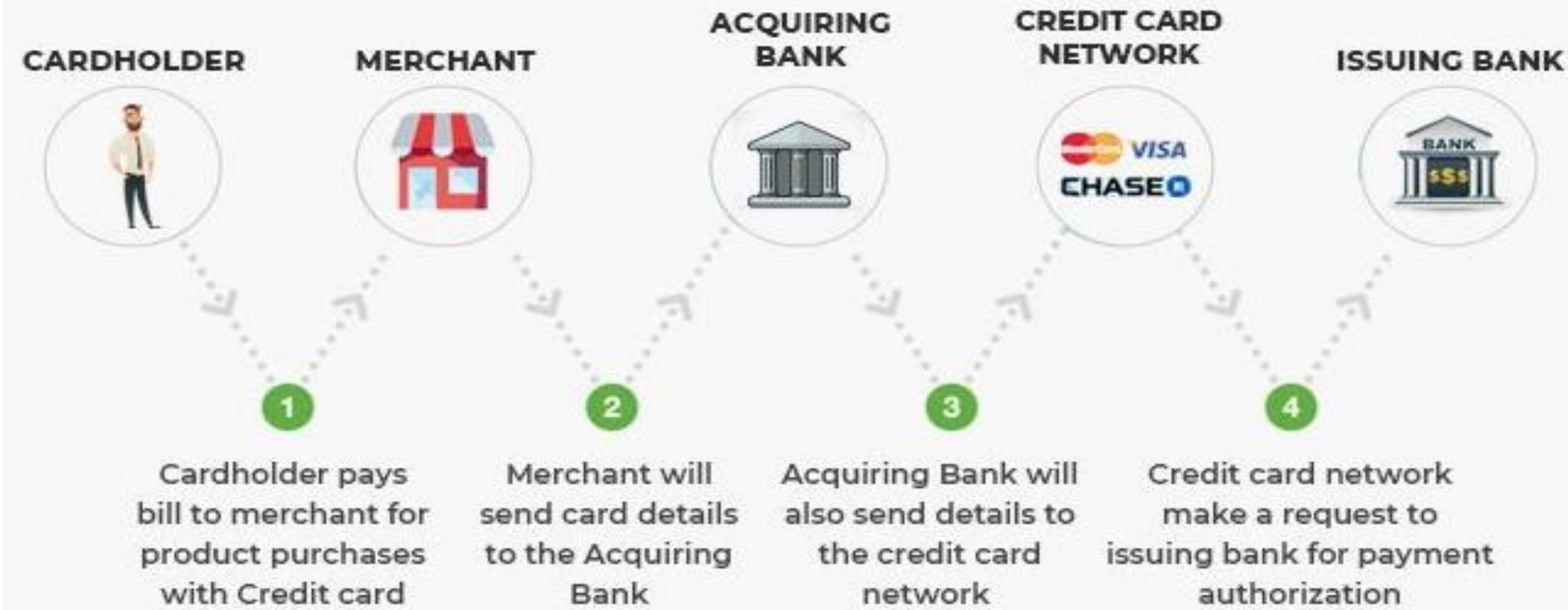


Authorization

Merchant must obtain payment approval from Issuing Bank.

- Card holder present credit card for payment at merchant point of sale (POS)terminal.
- Customers call details are send to the acquiring bank (or its processor/service provider) via an internet connection or phone line.
- The acquiring bank (or processor/ service provider) forward the details the payment brand network.
- Payment brand network request authorisation from the issuing bank.

Authorization

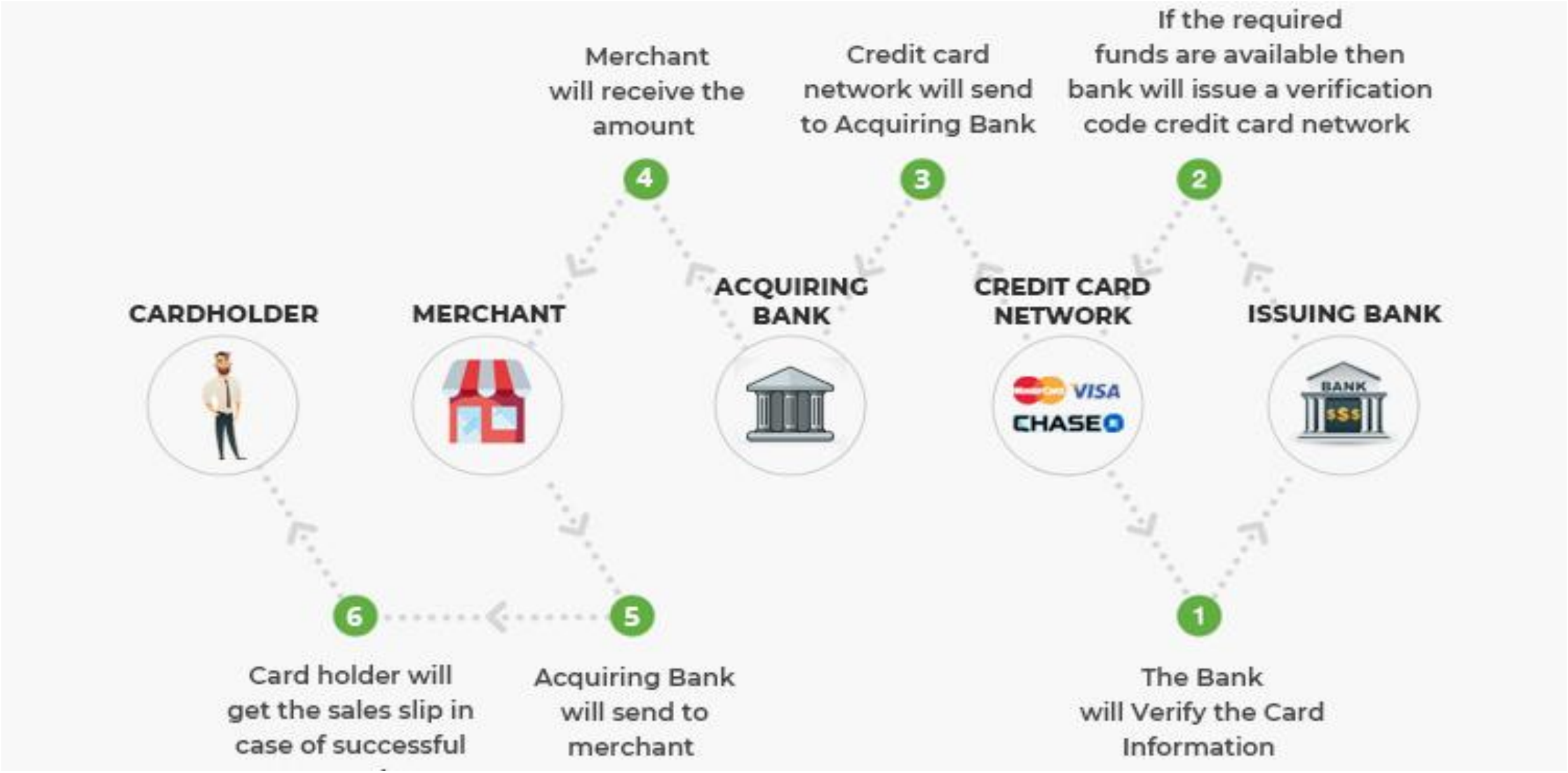


Source- https://www.temok.com/blog/pci-compliant-hosting/

Authentication

- Issuing Bank receives authorisation request.
- Issuing Bank validates the credit card number, checks the amount of available funds, matches the building address validates CVV.
- Issuing Bank approves or declines the transaction.
- Issuing Bank Places of hold in the amount on the cardholder's account.
- Merchant’s POS terminal will collect all approved authorisations to be processed in a batch EOD.
- Person provides the customer receipt to complete the sale.

AUTHENTICATION



Clearing and Settlement

- At EOD, merchant's send approved authorized transaction in a batch to the acquiring bank for its processing.
- Processor routes the batch information to the payment brand network in a clearing message for settlement.
- The payment brand network forwards each approved transaction to the corresponding issuing bank.
- Within 24 to 48 hours of the transaction the issuing bank will transfer the funds to the acquiring bank via the payment brand network.
- The payment brand network and the issuing bank will transfer funds after charging the "interchange fees".
- Acquiring bank transfers the amount to merchants account for purchases done by customer.
- The issuing bank post the transaction to cardholder account and card holder pays the bill.

Clearing & Settlement

CARDHOLDER



MERCHANT



ACQUIRING BANK



CREDIT CARD NETWORK



ISSUING BANK



1. Approved list of transactions will be to the Acquiring Bank
2. Acquiring Bank will also send these batch files to credit card network
3. CCD will send each approved transaction to issuing bank
4. Bank transfers the funds to Acquiring Bank & charge interchange fee
5. CCD will pays the Acquiring Bank its percentage of remaining funds.
6. The Acquiring Bank credits merchant less a merchant discount rate.
7. The banks will post the transaction to cardholders' account & card holder will pay the bills.

PCI Data Security Standard – High Level Overview	
Build and Maintain a Secure Network and Systems	**1.** Install and Maintain Network Security Controls. **2.** Apply Secure Configurations to All System Components.
Protect Account Data	**3.** Protect Stored Account Data. **4.** Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks.
Maintain a Vulnerability Management Program	**5.** Protect All Systems and Networks from Malicious Software. **6.** Develop and Maintain Secure Systems and Software.
Implement Strong Access Control Measures	**7.** Restrict Access to System Components and Cardholder Data by Business Need to Know. **8.** Identify Users and Authenticate Access to System Components. **9.** Restrict Physical Access to Cardholder Data.
Regularly Monitor and Test Networks	**10.** Log and Monitor All Access to System Components and Cardholder Data. **11.** Test Security of Systems and Networks Regularly.
Maintain an Information Security Policy	**12.** Support Information Security with Organizational Policies and Programs.

Requirement 1: Install and Maintain Network Security Controls

Sections

1.1 Processes and mechanisms for installing and maintaining network security controls are defined and understood.

1.2 Network security controls (NSCs) are configured and maintained.

1.3 Network access to and from the cardholder data environment is restricted.

1.4 Network connections between trusted and untrusted networks are controlled.

1.5 Risks to the CDE from computing devices that are able to connect to both untrusted networks and the CDE are mitigated.

Understanding the parts of requirement

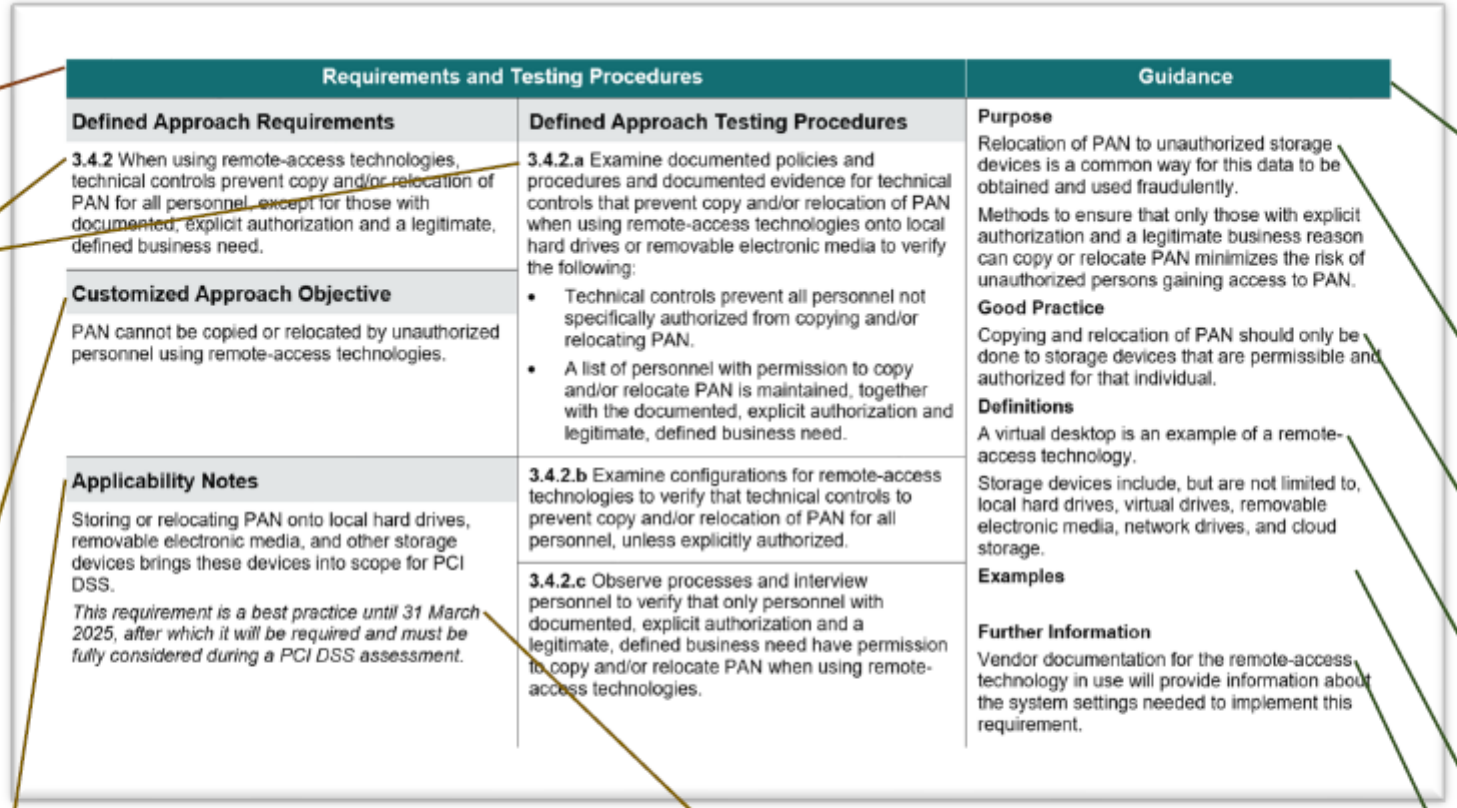
The **Requirement Description** at the X.X level organizes and describes the requirements that fall under it.

The **Defined Approach Requirements and Testing Procedures** describes the traditional method for implementing and validating PCI DSS using the Requirements and Testing Procedures defined in the standard.

The **Customized Approach Objective** is the intended goal or outcome for the requirement. It must be met by entities using a Customized Approach. Most PCI DSS requirements have this Objective.

Appendix D describes expectations for entities and assessors when the Customized Approach is used.

Entities following the Defined Approach can refer to the **Customized Approach Objective** as guidance, but the objective does not replace or supersede the Defined Approach Requirement.



Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** Relocation of PAN to unauthorized storage devices is a common way for this data to be obtained and used fraudulently. Methods to ensure that only those with explicit authorization and a legitimate business reason can copy or relocate PAN minimizes the risk of unauthorized persons gaining access to PAN. **Good Practice** Copying and relocation of PAN should only be done to storage devices that are permissible and authorized for that individual. **Definitions** A virtual desktop is an example of a remote-access technology. Storage devices include, but are not limited to, local hard drives, virtual drives, removable electronic media, network drives, and cloud storage. **Examples** **Further Information** Vendor documentation for the remote-access technology in use will provide information about the system settings needed to implement this requirement.
3.4.2 When using remote-access technologies, technical controls prevent copy and/or relocation of PAN for all personnel, except for those with documented, explicit authorization and a legitimate, defined business need.	**3.4.2.a** Examine documented policies and procedures and documented evidence for technical controls that prevent copy and/or relocation of PAN when using remote-access technologies onto local hard drives or removable electronic media to verify the following: • Technical controls prevent all personnel not specifically authorized from copying and/or relocating PAN. • A list of personnel with permission to copy and/or relocate PAN is maintained, together with the documented, explicit authorization and legitimate, defined business need.	
Customized Approach Objective PAN cannot be copied or relocated by unauthorized personnel using remote-access technologies.		
Applicability Notes Storing or relocating PAN onto local hard drives, removable electronic media, and other storage devices brings these devices into scope for PCI DSS. *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*	**3.4.2.b** Examine configurations for remote-access technologies to verify that technical controls to prevent copy and/or relocation of PAN for all personnel, unless explicitly authorized. **3.4.2.c** Observe processes and interview personnel to verify that only personnel with documented, explicit authorization and a legitimate, defined business need have permission to copy and/or relocate PAN when using remote-access technologies.	

Applicability Notes apply to both the Defined and Customized Approach. Includes information that affects how the requirement is interpreted in the context of the entity or in scoping.

These notes are an integral part of PCI DSS and must be fully considered during an assessment.

For each new PCI DSS v4.0 requirement with an extended implementation period.

Guidance provides information to understand how to meet a requirement. Guidance is not required to be followed – it does not replace or extend any PCI DSS requirement.

Not every **Guidance** section described here is present for each requirement.

Not every section will be present for each requirement.

Purpose describes the goal, benefit, or threat to be avoided; why the requirement exists.

A **Good Practice** can be considered by the entity when meeting a requirement.

Definitions Terms that may help understand the requirement.

Examples describe ways a requirement could be met.

Further Information includes references to relevant external documentation.

Requirements and Testing Procedures		Guidance
1.1 Processes and mechanisms for installing and maintaining network security controls are defined and understood.		
Defined Approach Requirements **1.1.1** All security policies and operational procedures that are identified in Requirement 1 are: • Documented. • Kept up to date. • In use. • Known to all affected parties. **Customized Approach Objective** Expectations, controls, and oversight for meeting activities within Requirement 1 are defined, understood, and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.	**Defined Approach Testing Procedures** **1.1.1** Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 1 are managed in accordance with all elements specified in this requirement.	**Purpose** Requirement 1.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 1. While it is important to define the specific policies or procedures called out in Requirement 1, it is equally important to ensure they are properly documented, maintained, and disseminated. **Good Practice** It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For these reasons, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. **Definitions** Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.

Requirement 2: Apply Secure Configurations to System Components

2.1 Processes for applying secure configurations are clearly defined

2.2 All system components are securely configured and managed

2.3 All wireless environments are securely configured and managed

Requirement 3: Protecting Account Data in Storage and Transmission

3.1: Processes for protecting stored account data are clearly defined

3.2: Account data in storage is kept to the minimum amount necessary

3.3: Sensitive account data (SAD) is not kept in storage after authorization

3.4: View and copy access to primary account numbers (PAN) is restricted

3.5: PANs and related data are secure everywhere they exist in storage

3.6: Cryptographic keys used to protect account data are secured

3.7: Processes for managing keys securely are clearly defined

Requirement 4: Encrypt CHD for Transmission on Open Networks

4.1: Processes for encrypting CHD are clearly defined

4.2: PANs are secured with strong cryptography for transmission.

Requirement 5: Protect Systems from Malicious Software

5.1: Processes for protecting against malware are clearly defined

5.2: Malicious software is detected, prevented, and/or addressed

5.3: Anti-malware mechanisms are installed and actively monitored

5.4: Anti-phishing mechanisms are in place to protect users from scams

Requirement 6: Develop and maintain secure systems and software

6.1: Processes for developing secure systems are clearly defined

6.2: All custom or bespoke software is developed securely

6.3: Vulnerabilities to software are identified and addressed

6.4: Public-facing web apps are safeguarded against attacks

6.5: All changes to apps and software are managed securely

Requirement 7: Restrict Access to CHD by Business Need to Know

7.1: Processes for restricting access by business need are clearly defined

7.2: Access to system components is appropriately defined and assigned

7.3: Access to system components is managed systematically

Requirement 8: Identify Users and Authenticate Access to Systems

8.1: Processes for identification and authentication are clearly defined

8.2: All user and admin IDs are managed throughout accounts' lifecycles

8.3: Strong authentication is established for user and admin accounts

8.4: Multi-factor authentication (MFA) is used to secure CDE access

8.5: MFA systems are configured securely to prevent misuse

8.6: Use of accounts and authenticating factors is strictly managed

Requirement 9: Restrict Physical Access to CHD Environments

9.1: Processes for physically restricting access to the CDE are clearly defined

9.2: Physical access controls mediate entry into all areas containing CHD

9.3: Physical access for visitors and personnel is authorized and managed

9.4: All media containing CHD is stored, accessed, and destroyed securely

9.5: Point of interaction (POI) devices are protected against misuse

Requirement 10: Log and Monitor Access to System Components

10.1: Processes for logging and monitoring access are clearly defined

10.2: Audit logs are used to support threat detection and forensic analysis

10.3: Audit logs are safeguarded against unauthorized changes

10.4: Audit logs are reviewed to identify suspicious activity

10.5: Audit log history is retained for future forensic analysis

10.6: Time-synchronization measures support consistent time settings

10.7: Failures of security systems are detected, reported, and responded to

Requirement 11: Test System and Network Security Regularly

11.1: Processes for network security testing are clearly defined

11.2: Wireless access points are monitored; unauthorized points are addressed

11.3: Internal and external vulnerabilities are identified, prioritized, and addressed

11.4: Internal and external penetration tests are performed regularly

11.5: Network intrusions and unexpected changes are detected and addressed

11.6: Unauthorized changes on payment pages are detected and addressed

Requirement 12: Support Information Security with Policies and Programs

12.1: Comprehensive security policies for information assets are kept current

12.2: Policies defining acceptable uses for technologies are implemented

12.3: Risks to the CDE are formally identified, evaluated, and managed

12.4: Processes for seamless PCI DSS compliance are managed

12.5: PCI DSS scope is carefully documented and validated

12.6: Employees are continuously trained on security awareness

12.7: Personnel are screened to minimize the risk of insider threats

12.8: Third-party service provider risks are managed thoroughly

12.9: Third-party service providers support customers’ compliance

12.10: Incidents that could impact the CDE are responded to immediately

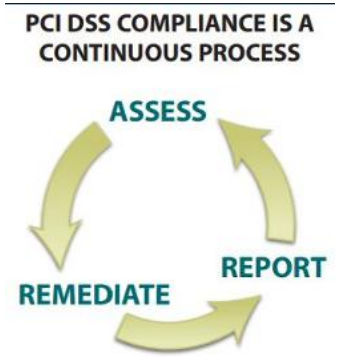
PCI DSS Assessment Process

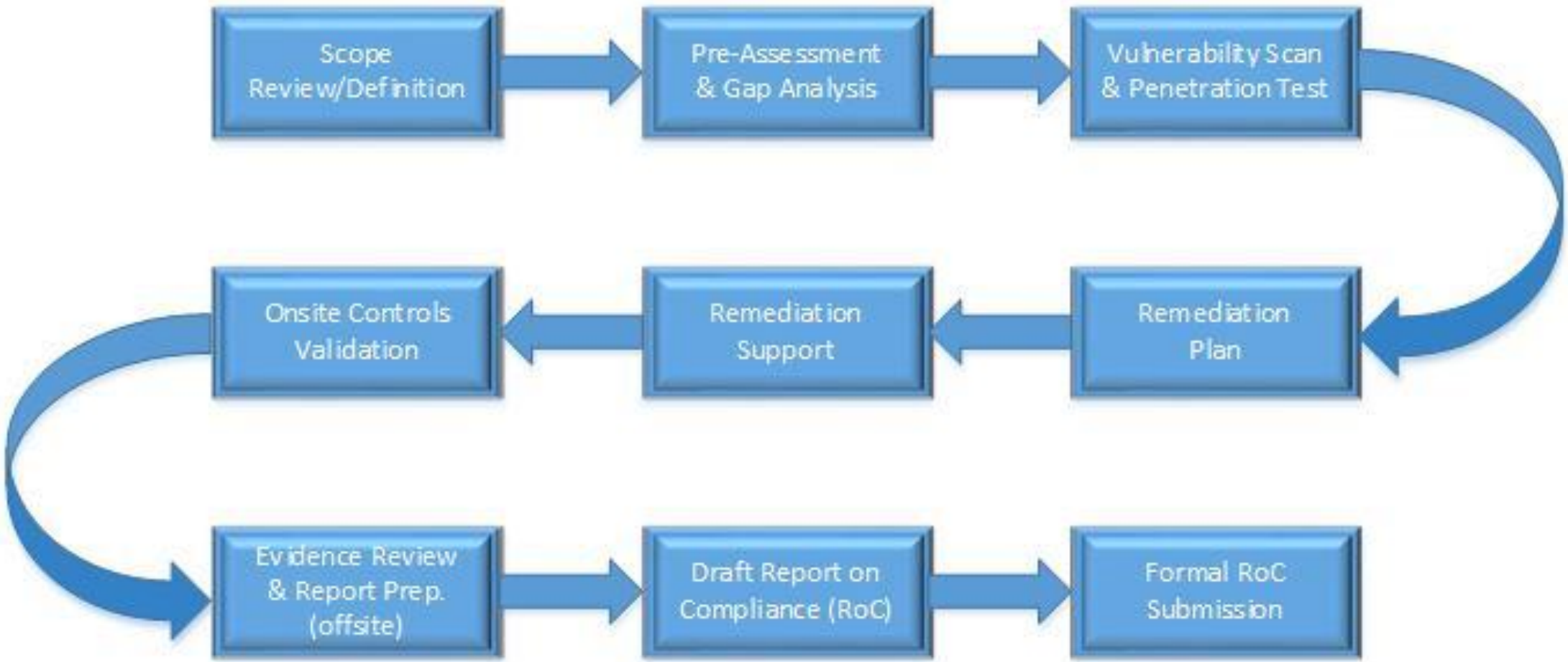
The PCI DSS assessment process includes the following high-level steps:5

1. Confirm the scope of the PCI DSS assessment.
2. Perform the PCI DSS assessment of the environment.
3. Complete the applicable report for the assessment according to PCI DSS guidance and instructions.
4. Complete the Attestation of Compliance for Service Providers or Merchants, as applicable, in its entirety. Official Attestations of Compliance are only available on the PCI SSC website.
5. Submit the applicable PCI SSC documentation and the Attestation of Compliance, along with any other requested documentation—such as ASV scan reports—to the requesting organization (those that manage compliance programs such as payment brands and acquirers (for merchants), or other requesters (for service providers)).
6. If required, perform remediation to address requirements that are not in place and provide an updated report.

PCI DSS Compliance Process

- Assessing
  - Testing and verifying controls in place to protect account data
- Remediating
  - Fix the vulnerabilities
- Reporting
  - Validate compliance and present evidence of data protection controls
- Monitoring & Auto Alerting
  - Constantly monitor access and usage of data, including the logs




Scope Review/Definition
Pre-Assessment & Gap Analysis
Vulnerability Scan & Penetration Test
Remediation Plan
Remediation Support
Onsite Controls Validation
Evidence Review & Report Prep. (offsite)
Draft Report on Compliance (RoC)
Formal RoC Submission

Report on Compliance

PCI DSS Requirement					
1.1.2 Roles and responsibilities for performing activities in Requirement 1 are documented, assigned, and understood.					
Assessment Findings (select one)				Select if below Method(s) Was Used	
In Place	**Not Applicable**	**Not Tested**	**Not in Place**	**Compensating Control***	**Customized Approach***
☐	☐	☐	☐	☐	☐
Describe why the assessment finding was selected. ***Note**: Include all details as noted in the "Required Reporting" column of the table in Assessment Findings in the ROC Template Instructions.* **As applicable, complete and attach the corresponding documentation (Appendix C, Appendix E, or both) to support the method(s) used.*					
Testing Procedures	Reporting Instructions	Reporting Details: Assessor's Response			
1.1.2.a Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 1 are documented and assigned.	**Identify** the evidence reference number(s) from Section 6 for all **documentation** examined for this testing procedure.				
1.1.2.b Interview personnel responsible for performing activities in Requirement 1 to verify that roles and responsibilities are assigned as documented and are understood.	**Identify** the evidence reference number(s) from Section 6 for all **interviews** conducted for this testing procedure.				

References

- https://static1.squarespace.com/static/5c89322704680180b88cc00/t/62af6ce45fcc0e5f6801c8d3/1655663846524/Mohan+Shamachar+-+RSI+Security+Presentation+-+PCI+DSS+4.0+06172022+%281%29.pdf
- https://www.controlcase.com/
- https://blog.pcisecuritystandards.org/topic/pci-dss-v4-0
- https://www.pcisecuritystandards.org/merchants/
- https://blog.pcisecuritystandards.org/pci-dss-v4-0-a-conversatio n-with-the-council
- https://www.rsisecurity.com
- https://www.pcisecuritystandards.org/